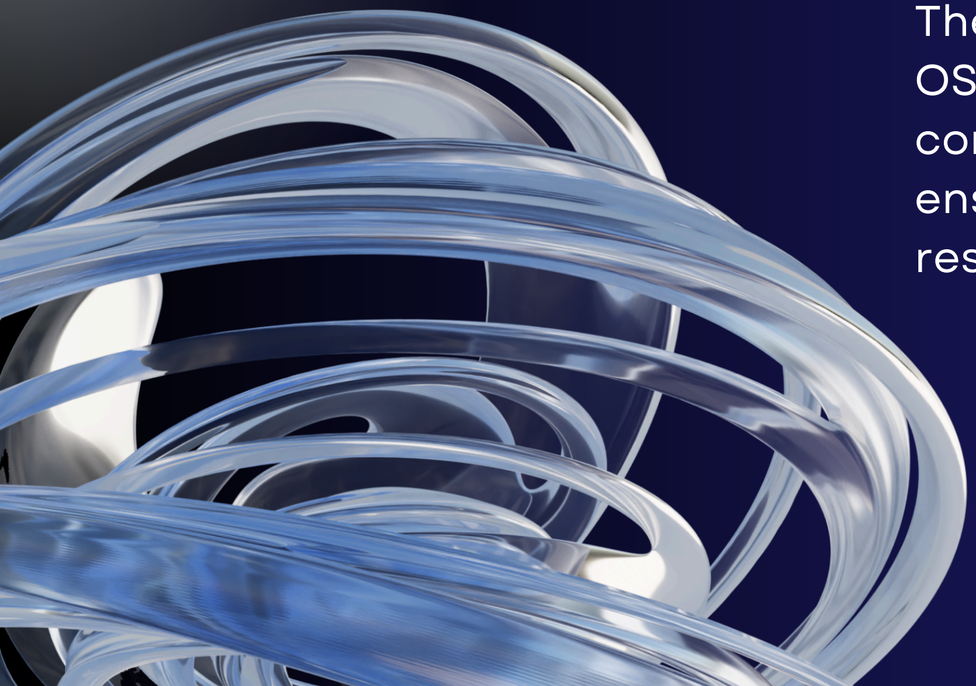
INTRODUCTION

Our strategy presents a clear approach to strengthening WowShop’s security posture across its digital and physical environments. It outlines the company’s profile, identifies key stakeholders, evaluates the current security environment, and summarizes the organization’s risk exposure.

The strategy also incorporates essential elements like software security, OS hardening, physical and infrastructure safeguards, and HR security controls aligned with international standards. These components ensure that the strategy supports effective governance, coordinated response, and long-term resilience against emerging threats.



ORGANIZATION ANALYSIS

Organization Profile:
WowShop is a small online clothing retailer with 100 employees, operating through a hybrid cloud environment and a single local office. Its core functions include product listings, secure payment processing, order management, customer support, and marketing.

The company relies on several key dependencies: a highly available e-commerce platform, PCI-compliant payment gateways (PayPal, Apple Pay, Mada), cloud services for hosting and storage, logistics partners like Aramex and DHL, and major social media platforms for marketing.

WowShop receives 3,000–10,000 daily visitors and processes 50–150 orders per day, with peak seasons reaching up to 30,000 visitors and 600 orders daily.

Our Key Security Stakeholders Includes:
1- Board of Directors
2- CTO (Chief Technology Officer)
3- IT Infrastructure Team
4- Customer
5- Third-party Vendors
6- Employees
7- Managers
8- Suppliers
9- Regulators
10- SOC (Security Operation Center) Team
11-GRC (Governance, Risk, Compliance) Team
12- CISO (Chief Information Security Officer) and CSO (Chief Security Officer)

CURRENT SECURITY ENVIRONMENT:

The WowShop identifies assets, analyzes threats, assesses vulnerabilities, and evaluates risk. It also links report weaknesses to the recommended controls, ensuring clarity and showing how the controls address the security gaps.

RISK ANALYSIS:

It identifies, evaluates, and prioritizes key risks to The WowShop's systems and customer data using a structured risk analysis aligned with ISO 27005 and NIST SP 800-30.

CATEGORIZATION OF THE IMPLEMENTED CONTROLS :

Control	Category
Security Policies & Procedures (Access Control Policy, Data Protection Policy)	Management Control
Risk Assessment & Risk Management Plan	Management Control
Business Continuity & Disaster Recovery Planning	Management Control
Security Awareness Governance	Management Control
Employee Cybersecurity Training & Awareness Programs	Operational Control
Incident Response Procedures	Operational Control
Log Review & Monitoring Activities	Operational Control
Physical Security Procedures	Operational Control
Backup Operations & Data Handling Processes	Operational Control
Firewalls (NGFW)	Technical Control
IDS/IPS (HIDS & NIPS)	Technical Control
Encryption (TLS 1.3, AES-256)	Technical Control
MFA & RBAC Access Controls	Technical Control
Endpoint Detection and Response (EDR)	Technical Control
Tokenization for Payment Data	Technical Control
Network Segmentation & Internal Segmentation Firewalls (ISFW)	Technical Control

OBJECTIVES : IDENTIFY AND MANAGE

IDENTIFY Function

- Identify and classify all assets (devices, data, apps, cloud).
- Understand critical business processes.
- Establish cybersecurity governance.
- Conduct regular risk assessments.
- Evaluate third-party risks (vendors, cloud providers).



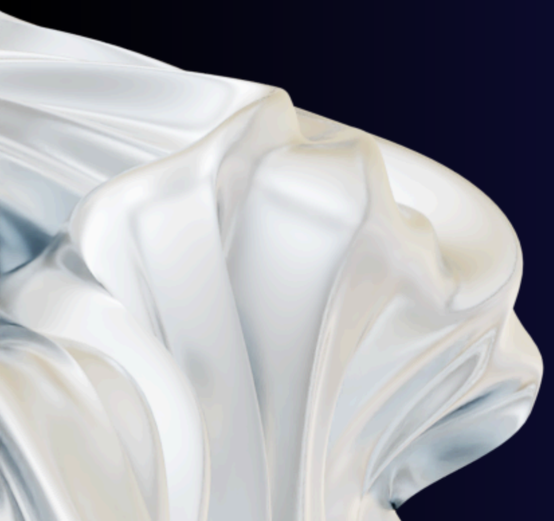
OBJECTIVES : DETECT AND PROTECT

PROTECT Function

- Enforce access controls (MFA, RBAC).
- Encrypt data in transit and at rest.
- Train employees to reduce human errors.
- Maintain updated security policies.
- Use protective tools (EDR, Firewalls, DLP).
- Apply patches and updates regularly.

DETECT Function

- Continuous monitoring using SIEM.
- Detect suspicious activity and anomalies.
- Analyze logs (firewall, IDS, IPS).
- Perform regular scans and tests.
- Set alert levels and escalation steps.



SOFTWARE USED IN WOWSHOP & KEY THREATS

Software Used in WowShop

WowShop relies on several interconnected software components, including the e-commerce platform, payment processing system, cloud hosting services, the DBMS, CMS, email system, inventory tools, and customer support systems.

Because these systems work together to support business operations, any weakness in one component can affect data confidentiality, system integrity, or service availability.

Key Software Threats

- SQL Injection (SQLi): Manipulating backend queries through malicious input.
- Cross-Site Scripting (XSS): Injecting harmful scripts into web pages.
- Cross-Site Request Forgery (CSRF): Forcing users to perform unintended actions.
- Weak or Misused APIs: Unauthorized access to backend functions or data.
- Outdated Third-Party Libraries: Known vulnerabilities in old components.
- Cloud Misconfigurations: Exposed storage, weak IAM roles, or open network settings.
- Improper Error Handling: Revealing system details that help attackers.
- Weak Session and Authentication Controls: Enabling impersonation or session hijacking.

SECURITY CONTROLS (NIST SP 800-53 + CIS CONTROLS V8)

NIST SP 800-53 Controls

- SI-10 – Information Input Validation: Prevents SQLi, XSS, and malformed data.
- AC-2 – Account Management: Controls account creation, privileges, and deactivation.
- SC-7 – Boundary Protection: Uses firewalls, WAF, and network segmentation to reduce exposure.
- RA-5 – Vulnerability Scanning: Identifies weaknesses across applications and cloud services.
- SI-2 – Flaw Remediation: Ensures timely patching of software and third-party libraries.
- CM-2 – Baseline Configuration: Applies secure and standardized configurations across environments.

CIS Controls v8

- Control 2 – Inventory and Control of Software Assets
- Control 4 – Secure Configuration of Enterprise Assets and Software
- Control 5 – Account Management
- Control 6 – Access Control Management
- Control 8 – Audit Log Management
- Control 16 – Application Software Security

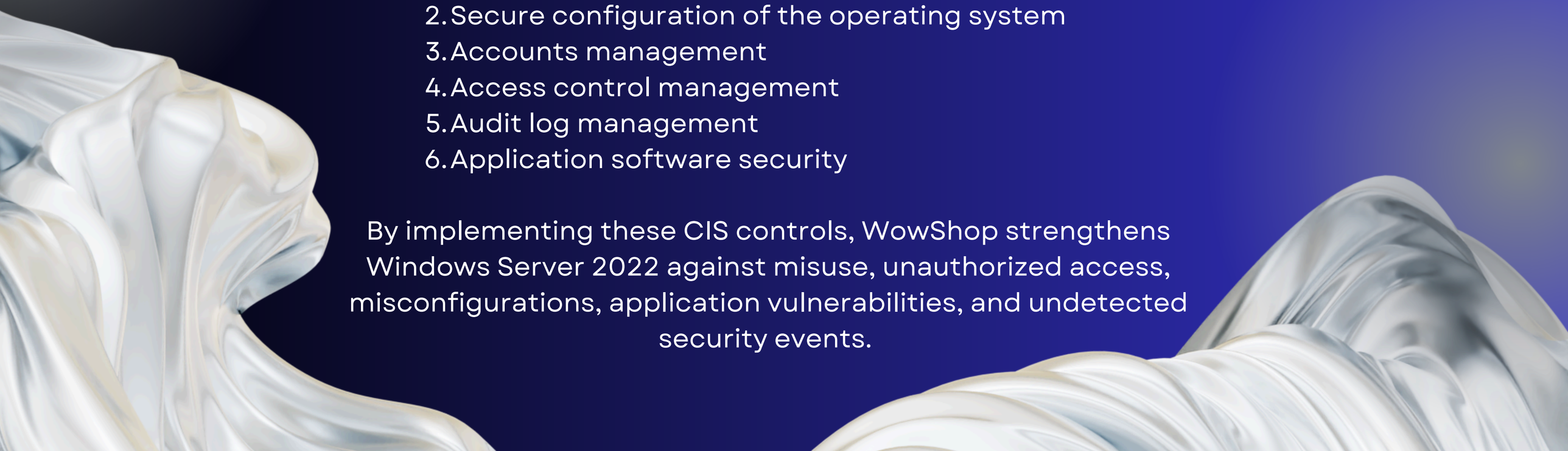
These controls collectively enhance software security, reduce exploitation risks, and support compliance with best practices.

SECURE AND HARDEN YOUR OS

The WowShop company applies selected CIS Controls to harden Windows Server 2022, focusing on secure configuration, access governance, software management, and system auditing.

1. Software for inventory and control
2. Secure configuration of the operating system
3. Accounts management
4. Access control management
5. Audit log management
6. Application software security

By implementing these CIS controls, WowShop strengthens Windows Server 2022 against misuse, unauthorized access, misconfigurations, application vulnerabilities, and undetected security events.



4.3 PHYSICAL & INFRASTRUCTURE SECURITY

Key Assets & Threats

- **Office & Warehouse:** Unauthorized access, tailgating, natural disasters
- **Server Room:** Overheating, power outages, unauthorized access, fire/water damage
- **Employee Workstations:** Theft, malware infection
- **Network Infrastructure:** Rogue AP/Evil Twin, misconfigurations
- **Hybrid Cloud:** Misconfigured storage, DDoS attacks, credential theft
- **IoT Devices (CCTV, Printers):** Weak passwords, outdated firmware

Security Controls

- **Facilities:** Access cards, visitor logs, security guards, anti-tailgating doors, CCTV
- **Server Room:** Biometric access, environmental controls, fire suppression, UPS
- **Workstations:** Full-disk encryption, MDM, USB restrictions
- **Network:** Firewall hardening, config reviews, 24/7 monitoring (IDS/IPS/SIEM)
- **Cloud:** MFA, config reviews, DDoS protection
- **IoT:** Change default passwords, disable unused services, VLAN segmentation, regular updates

HR SECURITY CONTROLS (ISO 27001) – WOWSHOP

Before Hiring

• Conduct identity and employment verification.
• Validate skills and qualifications.
• Perform legal/background checks when allowed.
• All new hires sign a confidentiality agreement

During Employment

• Ongoing security awareness training (updated every 6 months).
• Strict role-based access: employees access only what they need.
• Manager approval required for special permissions.
• Clear disciplinary actions for misuse of data or security violations.

End of Employment / Role Change

• Immediate deactivation of all system access on last working day.
• Collection of all company assets and MFA devices.
• Review of system logs to ensure no active sessions remain.



THANK YOU